

UD1 - Introducción a la seguridad informática

Conceptos fundamentales para la protección de sistemas e información.

Datos de la unidad	Información
Módulo	Seguridad y Alta Disponibilidad
Curso	2.º ASIR
Modalidad	Semipresencial
Duración	14 horas

Índice

1. [Fundamentos y principios de seguridad](#)
2. [Activos, riesgos y tipos de seguridad](#)
3. [Amenazas y vulnerabilidades](#)
4. [Medidas de protección y políticas](#)
5. [Gestión, respuesta y cumplimiento](#)
6. [Resumen](#)
7. [Recursos](#)
8. [Relación con los resultados de aprendizaje](#)

1. Fundamentos y principios de seguridad

1.1. Introducción

La información constituye uno de los activos más importantes de cualquier organización. Empresas, administraciones y usuarios particulares almacenan y procesan grandes cantidades de información mediante ordenadores, servidores, dispositivos móviles, redes y servicios en Internet.

La dependencia de los sistemas informáticos hace que una incidencia de seguridad pueda provocar consecuencias importantes:

- Pérdida de información.
- Robo de datos.
- Interrupción de servicios.
- Daños económicos.
- Pérdida de confianza de clientes y usuarios.
- Incumplimiento de obligaciones legales.
- Daños en la imagen de la organización.

La seguridad informática comprende el conjunto de técnicas, procedimientos, herramientas y medidas destinadas a proteger los sistemas de información frente a amenazas.

La seguridad debe gestionarse antes de que ocurra un incidente. Una organización que depende de sus aplicaciones, comunicaciones y datos necesita identificar qué activos son esenciales, qué puede fallar y cuánto tiempo puede estar sin cada servicio. El primer paso es realizar un análisis de riesgos que relacione activos, amenazas, vulnerabilidades, probabilidad e impacto; después se aplican controles proporcionados al valor del activo y al riesgo aceptable.

La seguridad absoluta no existe. Los sistemas incorporan software, hardware, redes, proveedores y personas, todos ellos sujetos a errores, cambios y nuevas amenazas. Además, reforzar un control puede tener coste económico o dificultar el uso de un servicio. Por este motivo, la seguridad se basa en la mejora continua: evaluar, proteger, comprobar los resultados y ajustar las medidas cuando cambie la organización o su entorno.

En esta unidad se estudiarán los conceptos fundamentales que permitirán comprender el resto del módulo.



Figura 1. La seguridad protege información, sistemas, redes y personas mediante controles coordinados.

1.2. Objetivos

Al finalizar esta unidad, el alumnado deberá ser capaz de:

- Identificar los principales conceptos relacionados con la seguridad informática.
- Diferenciar activo, amenaza, vulnerabilidad y riesgo.
- Comprender los principios fundamentales de la seguridad de la información.
- Identificar amenazas físicas y lógicas.
- Reconocer diferentes tipos de ataques informáticos.
- Analizar vulnerabilidades de sistemas y aplicaciones.

- Identificar medidas de seguridad preventivas y correctivas.
 - Comprender la importancia de las políticas de seguridad.
 - Analizar riesgos básicos de una infraestructura informática.
 - Conocer las fases generales de actuación ante un incidente.
 - Introducirse en las auditorías y el análisis forense.
 - Valorar la importancia de la seguridad desde el punto de vista técnico, organizativo y legal.
-

1.3. Conceptos fundamentales

1.3.1. Seguridad informática

La seguridad informática es el conjunto de medidas destinadas a proteger los sistemas informáticos, las redes, los dispositivos, las aplicaciones y la información frente a accesos no autorizados, alteraciones, pérdidas o interrupciones.

La seguridad no consiste únicamente en instalar un antivirus o un firewall.

Una infraestructura segura requiere combinar:

- Medidas técnicas.
 - Medidas físicas.
 - Medidas organizativas.
 - Formación de los usuarios.
 - Procedimientos de actuación.
 - Monitorización.
 - Copias de seguridad.
 - Actualizaciones.
 - Políticas de seguridad.
-

1.3.2. Seguridad de la información

La seguridad de la información busca proteger la información independientemente del formato en el que se encuentre.

Una información puede estar:

- Almacenada en un disco.
- En una base de datos.
- En un servidor.
- En un ordenador personal.
- En una copia de seguridad.
- En papel.
- En un dispositivo móvil.
- Transmitiéndose por una red.

Por tanto, la protección debe cubrir todo el ciclo de vida de la información.

1.4. Principios básicos de seguridad

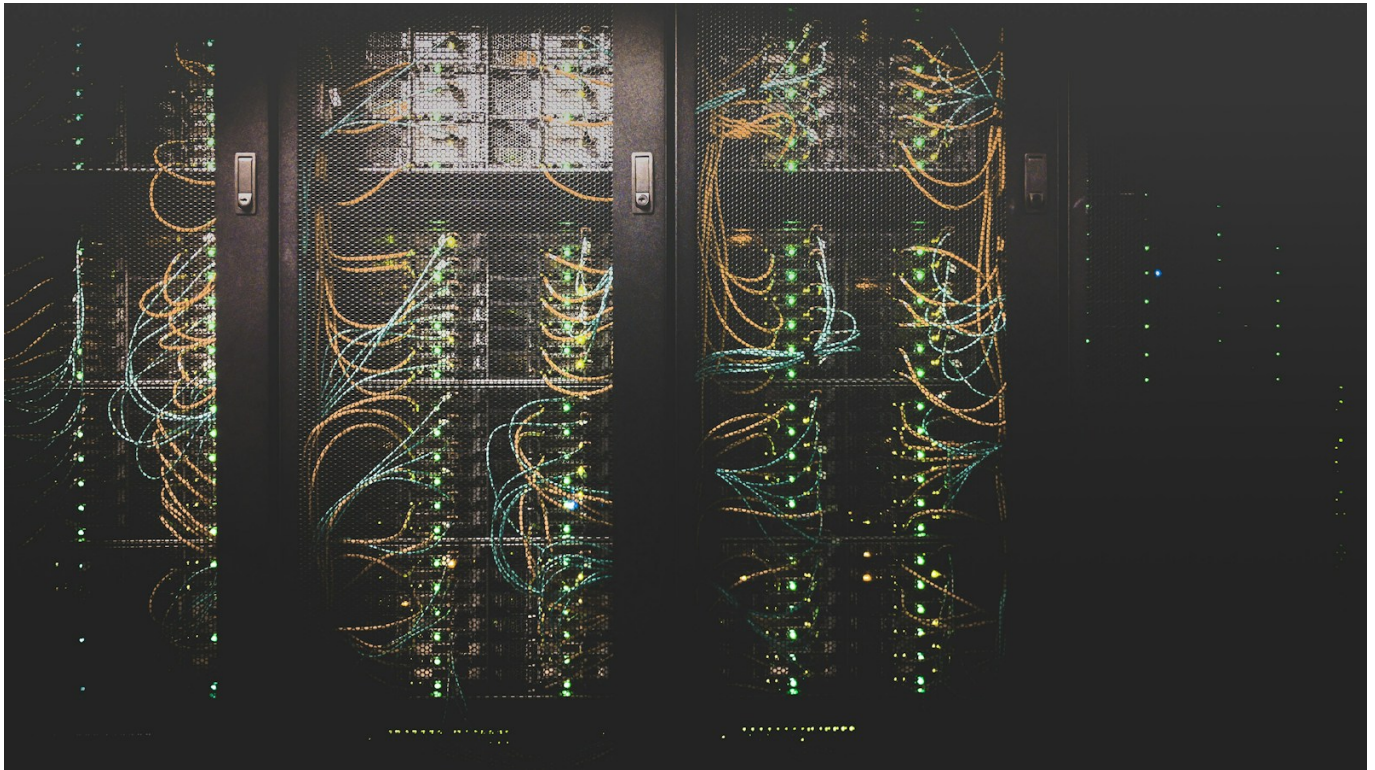


Figura 2. La protección debe abarcar la infraestructura, los servicios y la información que alojan.

Los tres principios clásicos de la seguridad informática forman la denominada **triada CIA**:

- Confidentiality → Confidencialidad.
- Integrity → Integridad.
- Availability → Disponibilidad.

1.4.1. Confidencialidad

La confidencialidad garantiza que la información solamente pueda ser consultada por las personas o sistemas autorizados.

Ejemplo:

Un empleado del departamento de administración debe poder consultar las nóminas, pero un usuario del departamento de mantenimiento no debería tener acceso a ellas.

Algunas medidas relacionadas con la confidencialidad son:

- Contraseñas.
 - Control de permisos.
 - Cifrado.
 - Autenticación multifactor.
 - Segmentación de redes.
 - Control de acceso.
-

1.4.2. Integridad

La integridad garantiza que la información no haya sido modificada de manera no autorizada.

Por ejemplo, si una base de datos contiene:

Saldo = 1.500 €

un atacante no debería poder modificarlo a:

Saldo = 15.000 €

sin que el sistema pueda detectar la modificación.

Algunas técnicas relacionadas con la integridad son:

- Hashes.
- Firmas digitales.
- Sistemas de control de versiones.
- Permisos.
- Auditorías.
- Registros de actividad.

1.4.3. Disponibilidad

La disponibilidad garantiza que los usuarios autorizados puedan utilizar la información y los servicios cuando los necesiten.

Un servidor puede ser muy seguro desde el punto de vista de la confidencialidad, pero si permanece apagado o inaccesible, no cumple adecuadamente su función.

Medidas relacionadas:

- Redundancia.
- RAID.
- Copias de seguridad.
- Alta disponibilidad.
- Balanceadores.
- Sistemas de alimentación ininterrumpida.
- Monitorización.
- Planes de recuperación.

1.4.4. Autenticidad

La autenticidad permite comprobar que una persona, dispositivo o sistema es realmente quien dice ser.

Ejemplos:

- Usuario y contraseña.
 - Certificados digitales.
 - Claves criptográficas.
 - Biometría.
 - Autenticación multifactor.
-

1.4.5. Trazabilidad

La trazabilidad permite conocer qué acciones se han realizado en un sistema y quién las ha realizado.

Por ejemplo:

```
10/09/2026 08:43
Usuario: admin
Acción: modificación de configuración
Equipo: servidor01
```

Los registros o logs son fundamentales para conseguir trazabilidad.

1.4.6. No repudio

El no repudio permite disponer de evidencias que dificulten que una persona pueda negar posteriormente una acción realizada.

Las firmas digitales son una de las principales tecnologías relacionadas con este concepto.

2. Activos, riesgos y tipos de seguridad

2.1. Activos

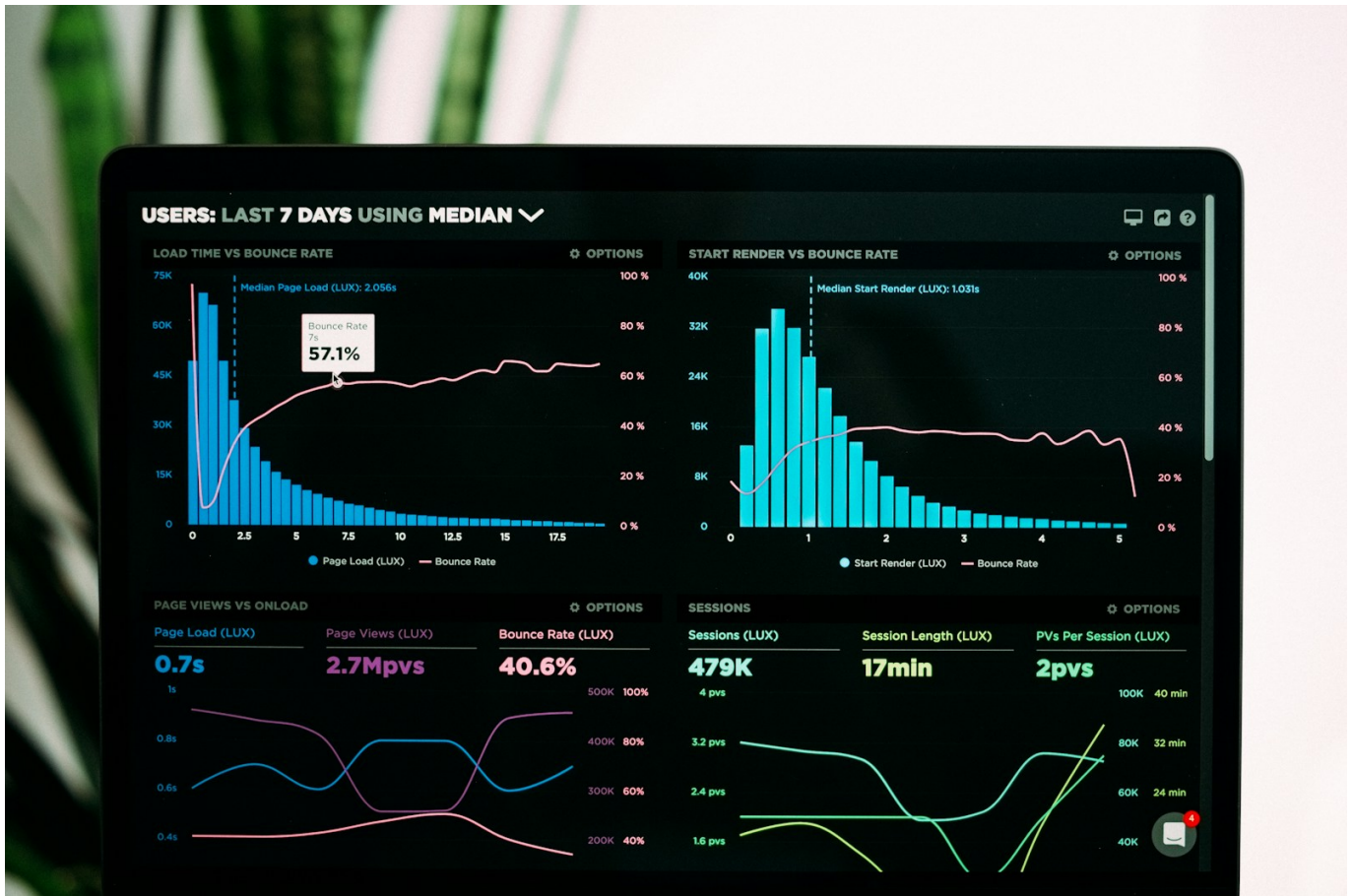


Figura 3. El análisis de riesgos permite priorizar la protección de los activos más importantes.

Un **activo** es cualquier elemento que tenga valor para una organización y que deba ser protegido.

Algunos ejemplos son:

- Servidores.
- Ordenadores.
- Routers.
- Bases de datos.
- Aplicaciones.
- Sistemas operativos.
- Información de clientes.
- Contraseñas.
- Certificados.
- Copias de seguridad.
- Instalaciones.
- Personal.

No todos los activos tienen el mismo valor.

Una base de datos con información de clientes puede tener una importancia mucho mayor que un ordenador utilizado únicamente para tareas administrativas.

2.2. Amenazas

Una **amenaza** es cualquier circunstancia que puede provocar un daño sobre un activo.

Las amenazas pueden ser accidentales o intencionadas.

2.2.1. Amenazas accidentales

- Fallo eléctrico.
- Error humano.
- Borrado accidental.
- Avería de hardware.
- Incendio.
- Inundación.

2.2.2. Amenazas intencionadas

- Robo.
 - Malware.
 - Ataques de red.
 - Phishing.
 - Robo de credenciales.
 - Sabotaje.
 - Acceso no autorizado.
-

2.3. Vulnerabilidades

Una **vulnerabilidad** es una debilidad técnica, física, organizativa o humana que puede ser aprovechada para provocar un daño. Puede estar presente en el diseño de una aplicación, en una configuración insegura, en un equipo sin actualizar o en un procedimiento que no define controles suficientes. Por sí sola no causa necesariamente un incidente, pero abre una posible vía de acceso o de alteración que debe identificarse, valorar y tratarse.

Ejemplos:

- Sistema operativo sin actualizar.
- Contraseña débil.
- Puerto innecesario abierto.
- Servicio vulnerable.
- Permisos excesivos.
- Falta de copias de seguridad.
- Configuración incorrecta.
- Aplicación vulnerable.

Una vulnerabilidad no implica necesariamente que exista un ataque.

Por ejemplo:

Servidor Linux
↓

```
SSH expuesto a Internet
  ↓
Contraseña débil
  ↓
Vulnerabilidad
```

Si un atacante aprovecha esa debilidad para acceder al servidor, estaríamos ante una explotación de la vulnerabilidad.

2.3.1. Amenaza y exploit

Una **amenaza** es una persona, un proceso, un evento o una circunstancia con capacidad de causar daño a un activo. Puede ser intencionada, como un intento de robo de credenciales, o accidental, como un fallo eléctrico. Un **exploit** es la técnica, procedimiento o herramienta que aprovecha una vulnerabilidad concreta para convertir esa posibilidad en un ataque real.

Por tanto, los tres conceptos se relacionan de esta forma:

```
Vulnerabilidad: debilidad existente
  ↓
Amenaza: agente o circunstancia que puede aprovecharla
  ↓
Exploit: técnica utilizada para explotarla
  ↓
Incidente: daño o acceso no autorizado
```

Por ejemplo, una aplicación web que no valida correctamente los datos introducidos presenta una vulnerabilidad. Un atacante constituye la amenaza y podría utilizar una técnica de inyección como exploit para intentar acceder o alterar información. La protección no depende de una única medida: requiere desarrollo seguro, actualizaciones, configuraciones adecuadas y supervisión de los registros.

2.3.2. Clasificación por tipo

Las vulnerabilidades pueden clasificarse por la naturaleza de la debilidad:

Tipo	Descripción	Ejemplo	Medida principal
Software	Errores de diseño, programación o validación de una aplicación.	Software sin parchear o validación de entradas deficiente.	Actualizaciones, desarrollo seguro y revisión de código.
Configuración	Ajustes inseguros o servicios expuestos sin necesidad.	Credenciales por defecto o puerto de administración accesible desde Internet.	Hardening, mínimo privilegio y revisión periódica.
Física	Falta de protección de equipos, instalaciones o soportes.	Acceso no controlado a un servidor o robo de un portátil.	Control de acceso, inventario y cifrado de dispositivos.

Tipo	Descripción	Ejemplo	Medida principal
Red	Debilidades en protocolos, segmentación o configuración de comunicaciones.	Wi-Fi mal protegido o tráfico sin cifrar.	Segmentación, cifrado y configuración segura.
Hardware	Deficiencias en componentes físicos o firmware.	Vulnerabilidades conocidas de procesadores o firmware desactualizado.	Actualizaciones de firmware y medidas de mitigación del fabricante.
Humana	Errores, falta de formación o procedimientos inadecuados.	Phishing, contraseñas débiles o envío erróneo de información.	Formación, MFA y procedimientos de verificación.

2.3.3. Clasificación por origen

- **Inherentes:** proceden del diseño o desarrollo original de un sistema; por ejemplo, un mecanismo de autenticación mal implementado.
- **Introducidas:** aparecen durante la instalación, configuración, operación o mantenimiento; por ejemplo, un servicio innecesario habilitado o permisos excesivos.
- **Derivadas:** surgen de la interacción entre componentes, versiones o dependencias; por ejemplo, una extensión incompatible con la aplicación principal.
- **De terceros:** afectan a proveedores, bibliotecas, servicios cloud o cadenas de suministro. Deben gestionarse mediante evaluación de proveedores, inventario de dependencias y aplicación controlada de actualizaciones.

También conviene diferenciar las vulnerabilidades conocidas con parche disponible, las conocidas sin corrección definitiva y las de tipo **zero-day**, que todavía no han sido reconocidas públicamente o no disponen de una solución del proveedor. Ante estas últimas se recurre a controles compensatorios, como restringir la exposición del servicio, segmentar la red y reforzar la monitorización.

2.4. Riesgo

El riesgo representa la posibilidad de que una amenaza aproveche una vulnerabilidad y provoque un impacto sobre un activo. Para gestionarlo no basta con enumerar problemas: es necesario identificar qué activos son importantes, qué amenazas les afectan, qué debilidades existen y qué consecuencias tendría un incidente. Esta valoración permite priorizar recursos, ya que no todos los riesgos requieren la misma respuesta.

De forma simplificada:

AMENAZA + VULNERABILIDAD → INCIDENTE → IMPACTO

Una forma sencilla de valorar el riesgo es:

$$\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$$

Por ejemplo:

Amenaza	Probabilidad	Impacto	Riesgo
Fallo de disco	Alta	Medio	Alto
Robo de portátil	Media	Alto	Alto
Incendio	Baja	Muy alto	Alto
Phishing	Alta	Alto	Muy alto

Esta valoración permite establecer prioridades. Una vez valorado, el riesgo puede reducirse aplicando controles, transferirse mediante un seguro o un servicio especializado, aceptarse de forma justificada cuando su coste sea desproporcionado o evitarse eliminando la actividad que lo origina. Las decisiones deben documentarse y revisarse cuando cambie la infraestructura, aparezcan nuevas amenazas o se produzca un incidente.

2.5. Tipos de seguridad

2.5.1. Seguridad física

Protege los elementos físicos de la infraestructura.

Ejemplos:

- Cerraduras.
- Cámaras.
- Control de acceso.
- SAI.
- Sistemas contra incendios.
- Control de temperatura.
- Sistemas de detección de humo.

2.5.2. Seguridad lógica

Protege los sistemas mediante mecanismos relacionados con software y configuración.

Ejemplos:

- Usuarios.
- Contraseñas.
- Permisos.
- Firewalls.
- Antivirus.
- Cifrado.

- Sistemas IDS/IPS.
-

2.5.3. Seguridad activa

Busca prevenir, detectar o detener incidentes.

Ejemplos:

- Firewall.
 - IDS.
 - IPS.
 - Antivirus.
 - Sistemas de monitorización.
 - Autenticación.
-

2.5.4. Seguridad pasiva

Su objetivo principal es reducir las consecuencias de un incidente.

Ejemplos:

- Copias de seguridad.
 - RAID.
 - SAI.
 - Sistemas redundantes.
 - Planes de recuperación.
-

3. Amenazas y vulnerabilidades

3.1. Principales amenazas informáticas

3.1.1. Malware

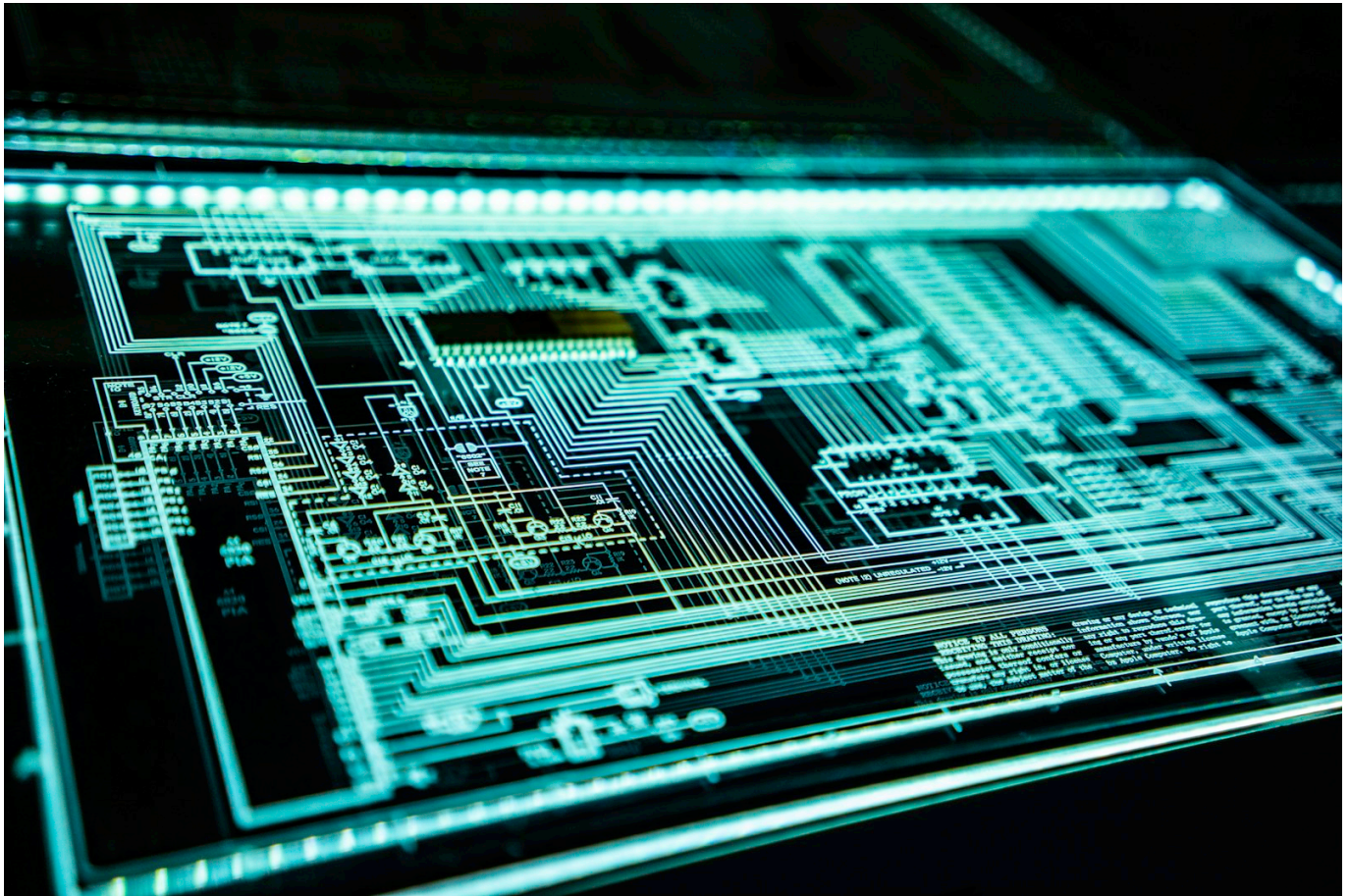


Figura 4. La protección frente a amenazas combina controles técnicos, actualización y vigilancia.

Malware es un término general utilizado para referirse a software malicioso diseñado para alterar el funcionamiento de un equipo, obtener información o facilitar un acceso no autorizado. Puede llegar mediante adjuntos de correo, descargas no verificadas, soportes extraíbles, páginas comprometidas o la explotación de programas vulnerables. Su impacto depende de los permisos obtenidos y del acceso del equipo a otros sistemas de la organización.

Entre sus principales tipos encontramos:

Virus

Programa capaz de propagarse infectando otros archivos.

Gusanos

Programas capaces de propagarse automáticamente a través de redes.

Troyanos

Programas que aparentan realizar una función legítima pero incorporan funcionalidades maliciosas.

Ransomware

Malware que cifra o bloquea información para exigir posteriormente un pago.

Spyware

Software diseñado para obtener información sobre las actividades del usuario.

Keylogger

Herramienta que registra las pulsaciones del teclado.

La protección frente a malware combina medidas preventivas y de detección: mantener el sistema operativo y las aplicaciones actualizados, utilizar protección antimalware, limitar privilegios, filtrar el correo, mantener copias de seguridad verificadas y analizar alertas o comportamientos anómalos. Ninguna de estas medidas es suficiente de forma aislada; la defensa mejora al aplicar varias capas.

3.2. Ingeniería social

La ingeniería social consiste en manipular a las personas para conseguir información o provocar determinadas acciones. En lugar de atacar directamente un sistema, el atacante explota la confianza, la urgencia, la curiosidad o la falta de procedimientos de verificación. Puede presentarse por correo electrónico, llamada telefónica, mensajería, redes sociales o incluso mediante acceso físico a instalaciones.

El atacante puede intentar conseguir:

- Contraseñas.
- Información personal.
- Códigos de autenticación.
- Acceso físico.
- Información empresarial.

La principal característica de estos ataques es que aprovechan el comportamiento humano. Para reducir el riesgo, el personal debe verificar solicitudes inusuales por un canal alternativo, evitar compartir credenciales o códigos MFA, y comunicar de inmediato cualquier intento sospechoso. Las políticas claras y la formación periódica son controles tan importantes como las herramientas técnicas.

3.3. Phishing

El phishing consiste en intentar engañar al usuario utilizando comunicaciones fraudulentas que aparentan proceder de una entidad conocida. Su objetivo puede ser robar credenciales, inducir una transferencia, instalar malware o conseguir información personal. Aunque el correo electrónico es el canal más habitual, también pueden utilizarse mensajes SMS, llamadas telefónicas o redes sociales.

Ejemplo:

AVISO DE SEGURIDAD

Su cuenta será bloqueada.

Acceda al siguiente enlace para verificar sus datos:
<https://ejemplo-falso.com>

El objetivo puede ser obtener:

- Usuario.
- Contraseña.
- Datos bancarios.
- Códigos MFA.
- Información personal.

Para reducir el riesgo es importante comprobar:

- Remitente.
- Dominio.
- Enlaces.
- Ortografía.
- Contexto del mensaje.
- Solicitudes urgentes o inesperadas.

Además, las organizaciones pueden aplicar filtros de correo, autenticación de dominio, MFA, bloqueo de enlaces maliciosos y un procedimiento sencillo para informar de mensajes sospechosos. Antes de facilitar información o acceder a un enlace, debe verificarse la petición a través de la web oficial o un contacto conocido, no mediante los datos incluidos en el mensaje.

3.4. Ataques de fuerza bruta

Un ataque de fuerza bruta consiste en probar diferentes combinaciones hasta encontrar una contraseña válida. También puede reutilizar contraseñas filtradas previamente en otros servicios, práctica conocida como *credential stuffing*. Estos ataques son más eficaces cuando se usan contraseñas cortas, predecibles o compartidas entre distintos sistemas.

Por ejemplo:

```
0000
0001
0002
0003
...
9999
```

La resistencia puede mejorarse mediante:

- Contraseñas largas.
- Bloqueo temporal.
- Limitación de intentos.
- MFA.
- Políticas de contraseñas.
- Monitorización.

También es recomendable revisar los intentos fallidos de inicio de sesión, impedir el uso de contraseñas conocidas como comprometidas y separar las cuentas de administración de las cuentas de uso diario. La MFA reduce de forma significativa el impacto de una contraseña robada, aunque no sustituye una buena gestión de identidades.

3.5. Denegación de servicio

Un ataque de denegación de servicio busca impedir o dificultar que un servicio pueda ser utilizado. El atacante intenta agotar recursos de un servidor, una aplicación o una conexión de red para que los usuarios legítimos no puedan utilizarlo. En un ataque distribuido, denominado **DDoS**, el tráfico puede proceder de numerosos dispositivos, lo que hace más difícil distinguir las peticiones legítimas de las maliciosas.

El objetivo es consumir recursos como:

- CPU.
- Memoria.
- Ancho de banda.
- Conexiones.
- Procesos.

Las medidas de protección incluyen filtrado y limitación de tráfico, monitorización, servicios especializados de mitigación, redundancia y distribución de los servicios. Un plan de respuesta debe definir quién recibe las alertas, cómo se escala el incidente y qué proveedores pueden intervenir cuando el ataque supera la capacidad de la infraestructura propia.

3.6. Vulnerabilidades de software

Los programas pueden contener errores de programación, fallos de diseño o dependencias inseguras que permitan realizar acciones no previstas. Una actualización no aplicada, una biblioteca obsoleta o una validación insuficiente de datos pueden exponer aplicaciones, servicios y sistemas operativos. Por ello, la gestión de vulnerabilidades debe formar parte del mantenimiento ordinario y no limitarse a actuar cuando aparece un incidente.

Las vulnerabilidades pueden identificarse mediante identificadores como los **CVE**.

La valoración de una vulnerabilidad puede complementarse mediante sistemas como **CVSS**, que ayuda a estimar su gravedad teniendo en cuenta factores como el acceso necesario, los privilegios requeridos y el impacto sobre confidencialidad, integridad y disponibilidad. El identificador no sustituye el análisis propio: una vulnerabilidad crítica puede tener poca exposición en un sistema aislado, mientras que una de gravedad media puede ser prioritaria en un servicio expuesto a Internet.

Por ello es importante:

1. Mantener actualizado el sistema.
2. Aplicar parches.
3. Eliminar software innecesario.
4. Monitorizar vulnerabilidades.
5. Revisar configuraciones.

El ciclo de gestión debe incluir inventario de activos y software, consulta de avisos del fabricante, evaluación de la exposición, pruebas antes de desplegar parches críticos y verificación posterior. Cuando no existe parche, se aplican medidas temporales como deshabilitar el servicio afectado, restringir el acceso de red, limitar permisos o aumentar la monitorización.

4. Medidas de protección y políticas

4.1. Gestión de usuarios y contraseñas



Figura 5. Las identidades, contraseñas y factores adicionales de autenticación controlan el acceso.

Una política de seguridad debe establecer criterios para las cuentas de usuario.

Algunas medidas:

- Cada usuario debe tener su propia cuenta.
 - Evitar cuentas compartidas.
 - Aplicar el principio de mínimo privilegio.
 - Utilizar contraseñas robustas.
 - Utilizar MFA cuando sea posible.
 - Bloquear cuentas inactivas.
 - Revisar periódicamente los permisos.
-

4.2. Principio de mínimo privilegio

Cada usuario o proceso debe disponer únicamente de los permisos necesarios para realizar su trabajo.

Por ejemplo:

```
Usuario: alumno
Permisos:
- Leer documentos de clase
- Ejecutar aplicaciones

No debería disponer de:
- Administrar usuarios
- Modificar configuración del sistema
- Instalar software sin autorización
```

Este principio reduce el impacto de una cuenta comprometida.

4.3. Políticas de seguridad

Una política de seguridad establece las normas que deben seguir los usuarios y administradores.

Puede incluir:

- Gestión de contraseñas.
- Uso de dispositivos.
- Acceso remoto.
- Copias de seguridad.
- Actualizaciones.
- Uso del correo electrónico.
- Navegación web.
- Gestión de incidentes.
- Control de accesos.
- Protección de datos.

Una política debe ser conocida por los usuarios y revisarse periódicamente.

5. Gestión, respuesta y cumplimiento

5.1. Auditorías de seguridad



Figura 6. Las auditorías, la monitorización y la respuesta documentada permiten mejorar la seguridad de forma continua.

Una auditoría de seguridad es un proceso sistemático que analiza una infraestructura, sus políticas y sus controles para comprobar su nivel de protección. No busca únicamente fallos técnicos: también revisa si existen procedimientos, si los permisos son adecuados y si se cumplen los requisitos legales y organizativos.

Puede revisar:

- Usuarios.
- Permisos.
- Servicios.
- Puertos.
- Actualizaciones.
- Configuración.
- Vulnerabilidades.
- Logs.
- Copias de seguridad.

Herramientas habituales en entornos ASIR incluyen:

- Lynis.
- OpenVAS/GVM.
- Nmap.
- Wazuh.
- Herramientas propias del sistema operativo.

El resultado debe ser un informe priorizado que describa el hallazgo, el activo afectado, el riesgo, la evidencia obtenida y una recomendación viable. Por ejemplo, una auditoría puede detectar que un servidor conserva una cuenta administrativa sin uso: la medida adecuada sería validar que no es necesaria, deshabilitarla y comprobar después que el servicio continúa funcionando.

5.1.1. Equipos de ciberseguridad

Las auditorías y los ejercicios de seguridad requieren roles definidos y autorización previa. En una organización pueden intervenir los siguientes equipos:

Equipo	Misión	Ejemplo de actividad
Red Team	Simula técnicas de un adversario para comprobar la resistencia de sistemas y procesos.	Ejecutar una prueba autorizada sobre una aplicación de entorno de pruebas e informar de las debilidades encontradas.
Blue Team	Protege, monitoriza, detecta y responde a incidentes.	Analizar alertas de un SIEM, aplicar un parche y mejorar una regla de detección.
Purple Team	Coordina al Red Team y al Blue Team para convertir los hallazgos en mejoras defensivas.	Verificar que una técnica simulada genera una alerta y ajustar la detección si no lo hace.
White Team	Define el alcance, las reglas y la supervisión de un ejercicio.	Establecer qué sistemas pueden analizarse, el horario y los criterios de parada.
Green Team	Implanta y mantiene las mejoras derivadas de los ejercicios.	Aplicar una configuración segura y documentar el cambio.

En el aula, cualquier práctica ofensiva debe realizarse solo sobre máquinas virtuales propias o sistemas autorizados. El valor de un ejercicio no está en causar impacto, sino en aprender a detectar, documentar y corregir una debilidad.

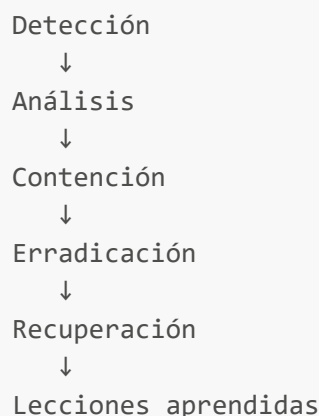
5.2. Gestión de incidentes

Un incidente de seguridad es un acontecimiento que puede afectar a la confidencialidad, integridad o disponibilidad de un sistema. Puede originarse en un ataque malicioso, un fallo técnico o un error humano. Una respuesta rápida, coordinada y documentada reduce el impacto y permite aprender de lo ocurrido.

Ejemplos:

- Cuenta comprometida.
- Infección por malware.
- Robo de información.
- Ataque de ransomware.
- Acceso no autorizado.
- Caída provocada por un ataque.

Una actuación básica puede dividirse en:



Durante la detección deben registrarse la fecha, los sistemas afectados, los síntomas observados y las acciones realizadas. La contención busca limitar la propagación sin destruir evidencias; por ejemplo, aislar una estación de trabajo comprometida de la red puede ser preferible a apagarla sin analizar su estado. Tras la recuperación se revisan las causas, los controles fallidos y las mejoras necesarias.

En España, las administraciones públicas cuentan con el apoyo del **CCN-CERT**, mientras que ciudadanos y empresas pueden recurrir a **INCIBE-CERT**. Cuando el incidente supera la capacidad interna de la organización, la notificación debe incluir información verificable y actualizada, evitando compartir datos sensibles por canales no autorizados.

5.3. Introducción al análisis forense

El análisis forense informático busca obtener y analizar evidencias relacionadas con un incidente de forma que puedan ser revisadas y, cuando proceda, tener validez en un procedimiento interno o judicial. La prioridad es no alterar la evidencia original y mantener una cadena de custodia que documente quién accede a cada elemento, cuándo y para qué.

Es importante preservar la información correctamente para evitar alterar las evidencias.

Algunas fuentes de información:

- Discos.
- Memoria RAM.
- Logs.
- Tráfico de red.
- Registros de aplicaciones.
- Historiales.
- Metadatos.

El análisis forense requiere procedimientos rigurosos y documentación de las actuaciones. Sus fases habituales son la adquisición de copias de trabajo, la preservación de los originales, el análisis de registros y artefactos, la documentación de herramientas y resultados, y la presentación de un informe comprensible. Por ejemplo, antes de investigar una posible intrusión en un servidor, se puede crear una copia forense, calcular su hash y analizar la copia, manteniendo el soporte original protegido.

5.3.1. CVE, CVSS y fuentes de información

Una **CVE** (*Common Vulnerabilities and Exposures*) es un identificador público para una vulnerabilidad conocida. Facilita que fabricantes, administradores y equipos de seguridad hablen del mismo problema. La puntuación **CVSS** ayuda a estimar la gravedad técnica en una escala de 0 a 10, pero la prioridad real también depende de la exposición del sistema y de los controles ya existentes.

Por ejemplo, una CVE crítica en un servicio expuesto a Internet debe revisarse con urgencia; la misma vulnerabilidad en una máquina de entorno de pruebas aislada puede tener menor prioridad. Las fuentes habituales para mantenerse informado son la [NVD de NIST](#), los avisos de fabricantes, [INCIBE-CERT](#) y [CCN-CERT](#). El procedimiento debe incluir inventario de versiones, evaluación, parche o medida compensatoria y verificación posterior.

5.4. Cumplimiento, normas y gestión del riesgo

El cumplimiento legal forma parte de la seguridad porque obliga a proteger la información, demostrar que se aplican controles adecuados y respetar los derechos de las personas. Cuando una organización trata datos personales debe considerar, entre otras normas, el **RGPD** y la **LOPDGDD**. Los datos personales incluyen identificadores, datos de contacto, localización, información económica o categorías especiales como datos de salud o biométricos.

El responsable del tratamiento determina para qué y cómo se usan los datos; el encargado los trata por cuenta del responsable. Algunas organizaciones deben designar un delegado de protección de datos (DPO), que asesora y supervisa el cumplimiento. Las medidas técnicas y organizativas, como el control de acceso, el cifrado, las copias de seguridad y los registros, ayudan a aplicar estos principios en la práctica.

5.4.1. Marcos de referencia

Marco	Aplicación principal	Aportación
ISO 31000	Gestión general del riesgo.	Proporciona principios para identificar, valorar, tratar y revisar riesgos.
ISO/IEC 27001	Sistemas de Gestión de Seguridad de la Información (SGSI).	Define requisitos certificables para organizar la seguridad de la información.
ISO/IEC 27002	Controles de seguridad.	Ofrece buenas prácticas para seleccionar e implantar controles.
ENS	Administraciones públicas españolas y proveedores afectados.	Establece principios y requisitos de seguridad para sistemas del sector público.
NIST Cybersecurity Framework	Gestión de ciberseguridad.	Organiza el trabajo en identificar, proteger, detectar, responder y recuperar.

La gestión del riesgo es un ciclo continuo: identificar los activos y amenazas, analizar probabilidad e impacto, decidir un tratamiento, implantar controles y revisar los resultados. Un centro educativo, por ejemplo, puede proteger los datos del alumnado mediante cuentas individuales, permisos por rol, MFA para cuentas administrativas, cifrado de portátiles, copias verificadas y un procedimiento de notificación de incidencias.

6. Resumen

La seguridad informática combina personas, procesos y tecnología para proteger los activos de una organización. El análisis de riesgos permite priorizar controles; la auditoría verifica su eficacia; los equipos de seguridad y la gestión de incidentes ayudan a detectar y mejorar; y el cumplimiento normativo garantiza que la protección respete obligaciones legales y derechos de las personas.

Los conceptos de activo, amenaza, vulnerabilidad, exploit, riesgo y control servirán de base para el resto del módulo. Una defensa eficaz no se basa en una única herramienta: aplica capas de protección, supervisión constante y mejora continua.

7. Recursos

- [Nmap](#)
- [Lynis](#)
- [Wazuh](#)
- [OWASP](#)
- [MITRE ATT&CK](#)
- [NIST Cybersecurity Framework](#)
- [INCIBE](#)
- [Material de apoyo: vulnerabilidades y amenazas](#)
- [Guías para empresas de INCIBE](#)
- [Guías CCN-STIC](#)

8. Relación con los resultados de aprendizaje

Esta unidad contribuye principalmente al:

RA1. Adopta prácticas seguras de utilización y trabajo con sistemas informáticos, reconociendo las vulnerabilidades y las necesidades de aseguramiento de los sistemas.

También introduce contenidos relacionados con:

RA7. Reconoce la legislación y normativa sobre seguridad y protección de datos.